DOCUMENT D14 · ABC BANK

Internal Audit report — Internal Controls Review: Cybersecurity

Report dated 3 March 2025, issued by the co-sourced internal audit provider. Fieldwork November 2024 – January 2025. Extract; machine names, file paths and product names removed.

1 Executive summary

In view of increased regulatory expectations on corporate governance and controls, ABC Bank requested its out-sourced internal auditor to perform a security review of its network and endpoint security, to help ensure cybersecurity resilience and recommend improvements to operational resilience. Management comments on each observation are incorporated.

Scope. (1) External reconnaissance to identify the bank's external-facing services, followed by automated and manual penetration testing and exploitation attempts on vulnerable elements; (2) simulated real-world attacks to evaluate preventive and detective capabilities against the latest threats, covering 30 tactics, techniques and procedures in the MITRE ATT&CK framework.

Work performed. Interviews with key management and process owners, and security testing designed to assess the adequacy and effectiveness of the design and operation of internal controls over cybersecurity.

Overall assessment	High	Medium	Low	Informational	Total
Number of findings	0	4	2	0	6

2 Summary of observations

Ref	Observation	Rating	Owner	Target date
3.1	Insecure remote desktop software usage (no MFA; credentials stored on a shared drive)	Medium	Head of IT / VP Information Security	1 Nov 2025
3.2	Insufficient user awareness on handling sensitive information (credentials and personal data on shared drives)	Medium	Head of IT / VP Information Security	31 Dec 2025
3.3	Insufficient data loss prevention (test files exfiltrated undetected)	Medium	Head of IT / VP Information Security	30 Sep / 1 Nov 2025
3.4	Insecure network segmentation within the internal network (RDP reachable from the user subnet to critical servers)	Medium	Head of IT / VP Information Security	31 Dec 2025
3.5	Endpoint and network protection against malicious activities could be enhanced	Low	Head of IT / VP Information Security	30 Sep 2025
3.6	Email security could be enhanced	Low	Head of IT / VP Information Security	30 Jun 2025 / 30 Jun 2026

3 Example of a detailed observation (3.3)

Observation	**Test files containing personal data were exfiltrated from a testing machine inside the bank's network without detection or blocking — via file-sharing websites, public cloud storage and a publicly hosted web server.**
Implication	Without effective data loss prevention (DLP) controls, attackers and malicious insiders may exfiltrate sensitive information, including customers' personal data.
Recommendation	Quick win: restrict access to file-sharing sites and public cloud storage unless required and authorised. Long term: assess a DLP solution to detect and prevent unauthorised exfiltration.
Management response	Implement web content filtering; deploy an endpoint DLP policy for labelled files.
Rating / owner / date	Medium · Head of IT / VP Information Security · 30 Sep 2025 (action 2), 1 Nov 2025 (action 1)

Appendix — risk rating scale

Rating	Definition
High	A weakness which could cause, or is causing, severe disruption to, or significant impact on, the bank.

Rating	Definition
Medium	Of lesser importance but still necessary for improving the overall environment and system integrity.
Low	A minor weakness with minimal impact; may represent good practice to further enhance security posture.
Informational	Not a threat to the system; recommendation based on experience and industry practice.

Limitations and disclaimer (extract)

“This is a point-in-time review of a complex area … the maintenance of an adequate system of internal control is the responsibility of management.”

“Our work does not constitute an audit or other assurance engagement in accordance with applicable professional standards. Accordingly, we provide no audit opinion, attestation or other form of assurance with respect to our work.”

Distribution: the report is for the bank’s use; a copy may be provided to the bank’s regulators and statutory auditor.

Sanitised teaching material. Re-typeset extracts of real governance documents; the institution’s name, all personal names, addresses, systems, vendors and other identifying details have been changed or removed. Do not attempt to identify the organisation and do not share outside CS5292.